

Siber Güvenlikte Parola Kırma Teknikleri

Siber Saldırı ve Savunma Yöntemleri - Hafta 7



Siber Güvenlikte Parola Kırma Teknikleri

Bu sunumda dijital dünyadaki temel kimlik doğrulama mekanizması olan parolalar, şifreleme ve özetleme (hash) kavramları ele alınacaktır. Parola saldırılarının türleri, yöntemleri ve bu saldırıları gerçekleştiren yaygın kullanılan açık kaynak kodlu araçlar (Hydra, John the Ripper, Hashcat, Crunch) incelenecektir. Saldırılara karşı alınabilecek temel önlemler ve teknik olmayan atak metotları açıklanacaktır.



Anahtar Kavramlar ve Öğrenme Hedefleri

Ünite sonunda öğrenciler:

Çevrimiçi (on-line) ve çevrimdışı (off-line) parola atakları deneme araçlarını tanıyacak.

Kaba kuvvet (Brute Force), Sözlük Saldırısı ve Gökkuşaağı Tablosu (Rainbow Table) tekniklerini öğrenecek.

Hash kodları ve parola kırma yöntemleri hakkında bilgi sahibi olacak.

Güvenli parola oluşturma ve parola güvenliği önlemlerini anlayacak.

Parola Kavramı

Parola, dijital dünyada birçok yerde (uygulamalar, web siteleri, cihaz arayüzleri) kimlik ve yetkilendirmeyi denetlemek için kullanılır.

Parolalar, sadece o parolayı belirleyen kişi tarafından bilinir ve belirli bir alana giriş yapmak için kullanılır.

Açık metin karakter dizilerinden oluşur ve genellikle kullanıcılar tarafından anlamlı dizelerden oluşturulan bilgilerdir.



Şifre (Cipher) Kavramı ve Şifreleme (Encryption)

Şifre, bir bilginin belirli algoritmalar kullanılarak başkaları tarafından çözülemeyecek ve okunamayacak şekle dönüştürülmüş hâlidir.

Şifreleme (Encryption), gizli bir anahtar kullanarak bilgilere yetkisiz erişimi engelleme yöntemidir.

Veriler, sadece anahtarı bilen yetkili kişiler tarafından okunabilir.

RSA (Asimetrik) ve AES (Simetrik) en sık kullanılan şifreleme algoritmalarındandır.



Hash (Özetleme) Kavramı

Hash, girilen veriyi sabit uzunlukta çıktıya dönüştüren matematiksel bir işlemdir.

Temel amacı, bir bilginin veri tabanında açıkça okunmasının önüne geçmektir. Bir uygulamaya üye olunurken parolalar, hashlenerek veri tabanında saklanır; böylece veri tabanına erişim olsa bile parolalar açıkça görülemez. md5 algoritması, hash tipinin en bilinen örneklerindendir.



Hash Örneği

Hash fonksiyonları tek yönlüdür; yani özetlenmiş (hashed) bilgiden orijinal parolaya geri dönmek teorik olarak zordur (tersine çevrilemez).

Örnek: Parola: siberguvenlik MD5 Formatında Şifreye Dönüştürülmüş Hâli:
d66db4bef25092ec53e6197ddf7ad85a

Bu özet, veri tabanında saklanan değerdir, gerçek parola değil.



Kodlama (Encoding) Kavramı

Kodlama, verinin farklı bir formata dönüştürülmesi işlemine verilen isimdir. Kodlamada temel amaç, verinin saklanması veya gizlenmesi değildir; amaç, verinin farklı sistemlerde rahatça işlem görebilmesidir. Popüler kodlama türleri arasında Base64, ASCII ve URL Encoding bulunur. Kodlama, şifreleme veya hash'ten farklı olarak kolayca tersine çevrilebilir (decode edilebilir).



Parola Saldırısı Nedir?

Parola saldırısı, dijital dünyada en sık rastlanan saldırı türlerindendir. Amacı, kurumsal veya kişisel araçların, web sitelerinin, programların veya kritik sistem noktalarının şifresini ele geçirmektir. Parolaların ele geçirilmesi ve kontrolün kaybedilmesi, kişi veya kurumları maddi ve manevi bakımdan zor durumda bırakabilir.



Zayıf Parolaların Rolü

Zayıf parolalar, bilinçsiz kişiler tarafından deneme yanılma yöntemi kullanılarak dahi çözülmeye çalışılabilir.

Kişisel bilgiler içeren parolalar (özel günler, takım isimleri, evcil hayvan isimleri), saldırganların deneme yanılma yöntemini kolaylaştırır ve büyük bir güvenlik açığı oluşturur.

Sık kullanılan ve kolaylıkla tahmin edilen parolalar (123456, qwerty, password) anında kırılır.



Güvenli Parola Kriterleri

Güvenlik için uzun, içeriğinde büyük ve küçük harf barındıran, aynı zamanda özel karakter bulunan parolalar belirlenmelidir.

Karmaşılaştırılmış parolaların kırılma süreleri bir hayli uzundur.

Çevrimiçi araçlar, belirlenen parolaların ne kadar sürede kırılabileceğini hesaplamak için mevcuttur.

Ancak çok karmaşık bir parola bile bazen saldırının önüne geçemeyebilir.



Bilgi Toplama (Reconnaissance) Aşaması

Bilgi toplama (istihbarat), siber saldırıların temelinde çok önemli bir yere sahiptir.

Parola ataklarında saldırganın karşı tarafla ilgili bilgi toplaması, parolanın çözümü için kritik önem taşır.

Saldırgan, hedef kişi veya kurumun web sitesi, sosyal medya hesapları ve kurumsal sektör bilgileri gibi istihbaratları kullanır.

Toplanan bilgilerden kelime listeleri oluşturulabilir ve bu listeler saldırılarda kullanılır.



Parola Ataklarına Karşı Güvenlik Önlemleri

Sistemi oluşturan kullanıcıların alacağı önlemler, kaba kuvvet tarzı deneme yanılma saldırılarının önüne geçebilir.

En sık kullanılan güvenlik önlemleri şunlardır:

Parola giriş ve deneme sayısını sınırlandırmak.

Fazla denemelerde uyarı sistemi ile bilgilendirmek ve kayıt altına almak.

Hatalı deneme yapan IP adreslerini engellemek.

Sistem Açıkları ve Hash Bilgileri

Parola ataklarında bir diğer yöntem, sistem açıklarını kullanarak sisteme sızmadır.

Sisteme sızıldığında elde edilen parola özetleri (hash bilgileri) ile karşı tarafın bilgileri ele geçirilebilir.

Ele geçirilen parola bilgileriyle birden fazla sisteme, cihaza veya oturum bilgisine erişilerek büyük zararlar verilebilir.



Parola Ataklarının Üç Ana Grubu

Parola atakları üç temel grupta incelenir:

1. Çevrimiçi (On-line) Parola Atakları
2. Çevrimdışı (Off-line) Parola Atakları
3. Teknik Olmayan Parola Atakları

Çevrimiçi Parola Saldırıları (On-line Attacks)

Çevrimiçi ataklar, anlık çalışan sistem üzerinde çeşitli araçlarla parola denemeleri yaparak gerçekleştirilen saldırılardır.

Bu saldırılarda kelime listeleri (wordlist) parola alanlarına uygulanır veya çalışan sistem dinlenip parolalar çözülür.

Temel amaç, hâlihazırda çalışan sistemin parolasını tespit etmektir.

Çevrimiçi Atak Araçları

Kali Linux işletim sistemi, parola atakları yapabilmek için birçok araç barındırır. Çevrimiçi parola saldırıları yapabilecek araçlara Kali Linux altında 'Password Attacks > Online Attacks' yoluyla ulaşılabilir.

Bu menüde acccheck, burpsuite, cewl, hydra, findmyhash, ncrack, medusa gibi açık kaynak kodlu araçlar bulunur.



Kaba Kuvvet Saldırıları (Brute Force)

Kaba kuvvet saldırıları, parolayı elde etmek için deneme yanılma yöntemi kullanılarak yapılan atak türleridir.

Yöntemin uygulanış kolaylığı, saldırganlar tarafından sıklıkla tercih edilmesini sağlar.

Parolanın karmaşıklığı, çözüm süresini uzatır; karmaşık bir parolanın çözümü günler sürebilir.

Bu saldırıları otomatikleştirmek için özel araçlar kullanılır.



Hydra Aracı (Kaba Kuvvet Aracı)

Hydra, Kali Linux on-line araçlar menüsünde bulunan ve kaba kuvvet saldırıları düzenlemek için kullanılan popüler bir araçtır.

Hydra aracı, FTP, SMTP, POP3, SSH, RDP, TELNET gibi birçok uzaktan erişim protokolünü destekler.

Diğer araçlara göre daha hızlıdır ve kelime listeleri kullanarak bir veya birden fazla hedefe eş zamanlı ataklar düzenleyebilir.

Kelime Listesi (Wordlist) Nedir?

Kelime listesi, içinde rakamlar, büyük ve küçük harfler, özel karakterler barındıran, parola olma ihtimali bulunan kombinasyonların bir araya geldiği listelerdir.

Bu listeler kullanıcılar tarafından hazırlanabilir veya internet üzerinden temin edilebilir.

Kelime listesi, sistemin şifresini barındırıyorsa atak başarıyla sonuçlanır; aksi takdirde sonuçsuz kalır.

Saldırının başarısı için listelerin atak yapılan yere uygun ve içeriğinin geniş olması önemlidir.



Hydra Komut Yapısı

Hydra'nın temel komut yapısı şöyledir:

```
hydra -l <kullanıcı adı> -P <parola> <ip adresi> <servis>.
```

Örnek Uygulama:

```
hydra -l user -P passlist.txt ftp://192.168.0.1
```

Bu komut, belirtilen IP adresinin FTP portuna 'user' kullanıcı adıyla ve 'passlist.txt' içindeki parolalarla kaba kuvvet saldırısı gerçekleştirir.

Hydra Parametreleri I

- l: Kullanıcı adı biliniyorsa bu parametre ile birlikte kullanıcı adı yazılır.
- L: Belirtilen dosya içinden kullanıcı adını tarar (Kullanıcı adı listesi).
- p: Parola biliniyorsa bu parametre ile birlikte parola yazılır (Tek parola denemesi).
- P: Belirtilen dosya içinden parolayı tarar (Parola kelime listesi).

Hydra Parametreleri II

- V: Denenen kombinasyonları ekrana yazdırır (Verbose modu).
- f / -F: Kullanıcı adı ile şifre bulunduğunda işlemi durdurur (Stop on success).
- s Port Numarası: Servis varsayılan portta değilse port tanımlanır.
- e nsr: Boş parola olduğunda (n), kullanıcı adı ile parolanın aynı olduğu durumları (s) veya rastgele parola denemelerini (r) tarar.

Uygulama 1: Hydra ile SSH Kaba Kuvvet Saldırısı

Hedef: 192.168.138.128 IP adresine sahip cihazın SSH servisi kullanıcı adını (root) ve parolasını (1234) elde etmek.

1. Adım: Hydra aracını Kali Linux'ta başlatmak.

2. Adım: Saldırı için gerekli kelime listeleri (users.txt ve pass.txt) hazırlanır ve masaüstüne kaydedilir.

Kelime listeleri, kullanıcı adları ve parola adaylarını içerir.

Uygulama 1: Hydra Komutunun Çalıştırılması

3. Adım: Terminalde kelime listelerinin içeriği kontrol edilir.

4. Adım: Saldırı komutu girilir:

```
root@Kali:/Desktop hydra -L users.txt -P pass.txt 192.168.138.128 ssh
```

Komutun anlamı: users.txt ve pass.txt listelerini kullanarak 192.168.138.128 adresindeki SSH servisine kaba kuvvet saldırısı yap.

5. Adım: Saldırı sonucunda doğru kullanıcı adı (root) ve şifre (1234) eşleştğinde saldırı başarılı olacaktır.

Medusa Aracı

Medusa, kaba kuvvet saldırılarının gerçekleştirilebileceği bir diğer açık kaynak kodlu araçtır.

Hydra gibi Medusa da birden fazla hedefe saldırı yapabilir ve kelime listelerini kullanır.

Medusa, AFP, CVS, FTP, HTTP, IMAP, MS-SQL, MySQL, SNMP, SSHv2, TELNET gibi çok çeşitli port ve servislere parola atakları gerçekleştirebilir.

Araca Kali Linux'ta 'Password Attacks > Online Attacks > medusa' yoluyla ulaşılır.

Medusa Temel Komut Yapısı

Medusa komutları, hedef IP adresi, kullanıcı adı/listesi, parola listesi ve hedef servisi (-M) içerir.

Örnek Komutlar:

```
medusa -h 192.168.138.128 -u root -P parolalistesi.txt -M http
```

```
medusa -h 192.168.138.128 -u root -P parolalistesi.txt -M ftp
```

Medusa Parametreleri I

- h: Sadece tek bir hedefe saldırı yapılacağında kullanılır (Tek IP).
- H: Birden fazla hedefe yapılacak saldırılarda kullanılır (Hedef listesi).
- u: Kullanıcı adı bilinen bir saldırı yapılacağında kullanılır (Tek kullanıcı adı).
- U: Birden fazla kullanıcı adı kelime listesinden deneneceğinde kullanılır (Kullanıcı listesi).

Medusa Parametreleri II

- p: Şifresi bilinen bir saldırı yapılacağında kullanılır (Tek parola).
- P: Birden fazla şifre kelime listesinden deneneceğinde kullanılır (Parola listesi).
- M: Bu parametre ile hedefteki servis bilgisi (modül) tanımlanır (örn: ssh, http, ftp).
- F: Parola ve kullanıcı adı bulunursa yapılan işlemin sonlanmasını sağlar. (Aksi halde denemeler devam eder).

Uygulama 2: Medusa ile SSH Saldırısı

Hedef: 192.168.138.128 IP adresine sahip cihazın SSH servisi kullanıcı adı ve parolasını kelime listeleri kullanarak elde etmek.

1. Adım: Medusa aracını Kali Linux'ta açmak.

2. Adım: Saldırı komutu girilir:

```
root@Kali:/Desktop medusa -h 192.168.138.128 -U users.txt -P pass.txt -M ssh -F
```

Komut, belirtilen adresin SSH servisine, kullanıcı ve parola listelerini kullanarak saldırır ve başarı durumunda durur (-F).

3. Adım: Saldırı sonucunda doğru kullanıcı adı ve şifresi (root, 1234) eşleştiğinde işlem başarılı olur.

Kelime Listesi Oluřturma Yöntemleri

Kaba kuvvet saldırıları için kullanılacak kelime listelerinin kullanıcının kendisi tarafından oluşturulması, daha verimli saldırılar yapma şansı verir.

Özelleřtirilmiř listeler, hedef cihazların parola ve kullanıcı adlarını daha hızlı çözme imkanı sağlar.

Kelime listesi oluşturmadan önce hedefle ilgili detaylı bilgi toplanmalıdır. Hedefe yönelik düzenlemeler yaparak yeni ve özelleřtirilmiř listeler oluşturulabilir.



Kelime Listesi Oluřturma Araçları

Kelime listesi oluşturmak için cewl, crunch, cupp gibi çeřitli açık kaynak kodlu araçlar bulunmaktadır.

Bu araçlar kullanılarak, farklı özelliklerde ve hedefe özel kelime listeleri hazırlanabilir.

Listeler oluşturulurken, daha önceden internete sızmış parola listeleri kontrol edilmeli ve benzerlikler aranmalıdır.

Cewl aracı, internet üzerindeki bir web sitesinin içinde geçen ifadelere göre bir kelime listesi hazırlamayı mümkün kılar.

Bu yöntem, hedefin kurumsal terminolojisini veya sık kullandığı anahtar kelimeleri tespit etmek için çok etkilidir.

Cewl, sitenin içeriğini analiz ederek, potansiyel parola olabilecek kelimeleri ayıklar.



Cewl Parametreleri

- v: Çıkan sonucu daha detaylı görmek için kullanılır (Verbose).
- d: Derinliği ifade eder (Kaç sayfa derine inileceği). Örneğin, 2. sayfada aramak için -d 2 şeklinde kullanılır.
- w: İşlem sonucunu istenilen dosya adıyla belirlenen yere kaydetmeye yarar (Write output).
- e: Sitede bulunan e-mail adreslerini çıkarır.
- m 6: En az 6 karakter uzunluğundaki kelimelerden oluşacak şekilde kelime listesi hazırlar (Minimum length).

Uygulama 3: Cewl ile Kelime Listesi Oluşturma

Hedef web sitesinin içindeki ifadeleri kullanarak, 'siberkitap.txt' isminde kelime listesi oluşturmak.

2. Adım: Aşağıdaki komut kullanılarak 2. derinlikte arama yapılır ve en az 10 karakterli kelimelerden oluşan liste oluşturulur.

```
root@Kali: cewl -d 2 -m 10 https://hedefwebsitesi -w  
/root/Desktop/siberkitap.txt
```

Oluşturulan kelime listesi masaüstünde konumlanacaktır.

Çevrimdışı Parola Saldırıları (Off-line Attacks)

Çevrimdışı saldırılar, anlık sistem yerine, sistemde kullanıcı adı ve parolaların saklandığı dizinlere ulaşmayı amaçlar.

Parolalar genellikle şifrelenmiş (encrypted) veya hash edilmiş (özetlenmiş) şekilde tutulur.

Saldırganın amacı, ele geçirdiği hash bilgilerinden orijinal parolalara ulaşmaktır.

Bu tür saldırılar Kaba Kuvvet, Sözlük Saldırıları ve Rainbow Table olmak üzere üç farklı türde gerçekleştirilir.



Linux Sistemlerde Parola Saklama

Linux tabanlı işletim sistemlerinde kullanıcı bilgileri `/etc/passwd` dosyasında saklanır.

Kullanıcıların parolaları ise `/etc/shadow` dosyasının içinde şifrelenmiş (hashlenmiş) şekilde bulunur.

Shadow dosyası, kök (root) yetkisine sahip kullanıcıya ait bilgileri de şifrelenmiş olarak içerir.



Shadow Dosyası Analizi

Shadow dosyasındaki ifadeler incelendiğinde 'root' kullanıcı adının hemen ardından gelen ikinci kısım, parolanın şifrelenmiş (hash) halidir. Bu alanda bulunan '\$' işaretleri, kullanılan özet alma algoritmasını belirtir. Örnek: '\$6\$' ifadesi, parolanın SHA 512 algoritması ile şifrelendiğini gösterir.

Temel Özetleme Algoritmaları (Shadow)

Shadow dosyasında yaygın kullanılan özet alma algoritmaları ve kodları şunlardır:

\$1\$: md5 algoritması

\$2y\$: Blowfish algoritması

\$5\$: SHA 256 algoritması

\$6\$: SHA 512 algoritması



John the Ripper (JTR)

John the Ripper (JTR), çevrimdışı parola atakları için kullanılan oldukça pratik bir hash kırma aracıdır.

Çevrimdışı atak yapmak için öncelikle hedef makineye sızılması ve hash dosyalarının ele geçirilmesi gerekir.

Ele geçirilen hash dosyaları ('passwd' ve 'shadow') 'unshadow' komutuyla birleştirilerek JTR tarafından okunabilir hale getirilir.

John the Ripper Parametreleri

- help: Kullanılacak parametrelerin listesini ve işlevlerini verir.
 - format: Şifreleme algoritmasına göre özel çözüm yapmak için kullanılır (Örn: --format=sha512crypto).
 - show: Hash bilgisi çözülen şifrenin ne olduğunu ekranda görüntüler.
- Kullanım Şekli: john [parametre] şifreli_dosya_yolu.

John the Ripper Parola Kırma Modları

JTR, kullanıcılara çeşitli parola kırma yöntemleri sunar:

1. Single Crack Modu: Yaygın kullanılan (yaklaşık 5000 adet) parolaları deneyerek şifreyi çözmeye çalışır. Örnek: john -single sifre.txt.
2. Kelime Listesi Kullanarak Kırma: Belirtilen kelime listelerini uygulayarak şifreyi kırmayı amaçlar.

JTR ayrıca kural tabanlı sözlük listesi saldırılarına da olanak tanır, bu sayede filtreleme yapılarak zaman kazanılır.

Uygulama 4: John ile SHA 512 Kırma

Hedef: Ele geçirilmiş 'sifreroot' adlı hash dosyasını John the Ripper aracıyla analiz ederek root parolasını elde etmek.

1. Adım: JTR aracını Kali Linux'ta başlatmak.

2. Adım: 'sifreroot' dosyasının içeriği görüntülenir. İçerikte '\$6\$' (SHA 512) kullanıldığı anlaşılır.

3. Adım: Atak komutu girilir:

```
root@Kali:/Desktop john sifreroot --show
```

(Not: JTR bu komutu çalıştırdığında önce saldırıyı gerçekleştirir, ardından '--show' ile bulunan parolayı gösterir.)

Uygulama 4: Parolanın Elde Edilmesi

Yapılan işlem sonucunda John the Ripper, hashlenmiş bilgiye karşılık gelen orijinal parolayı bulur.
Görsel çıktıda 'root' kullanıcısının parolasının '1234' olarak ele geçirildiği görülür.
Bu, çevrimdışı kaba kuvvet saldırısının başarıyla sonuçlandığını gösterir.

Hashcat Aracı

Hashcat, özet bilgisi olan birçok şifrelenmiş bilginin parolasını elde etmek için kullanılır.

Hashcat, CPU tabanlı işlemlerin yanı sıra Grafik İşlem Birimini (GPU) kullandığı için John the Ripper gibi araçlara göre çok daha hızlı şifre çözme işlemi gerçekleştirebilir.

Bu hız farkı, özellikle modern ve karmaşık hash algoritmaları için kritik öneme sahiptir.



Hashcat Kullanımı ve Parametreleri

Temel kullanım: hashcat [parametre] dosyanin_yolu [mask/kelime listesi].

-m (Mode): Hangi hash tipinin çözüleceğini belirtir (Örn: -m 0, md5 şifreleme için kullanılır).

-a (Attack Type): Saldırı modunu belirtir (-a 0, direkt saldırı/sözlük saldırısı parametresidir).

Örnek Komut: hashcat -m 0 -a 0 hashdosyasi.txt pass.txt

Bu komut, md5 hash'leri içeren dosyayı, pass.txt kelime listesi ile karşılaştırarak çözmeye çalışır.

Sözlük Saldırıları (Dictionary Attacks)

Sözlük saldırıları, elde bulunan hazır parola listelerinden (sözlük listelerinden) yararlanır.

Bu saldırı türünde, yaygın kullanıma sahip sistematik parola setleri kullanılır (doğum tarihleri, ad soyadı kombinasyonları, takım isimleri vb.).

İnternet ortamında ücretsiz veya ücretli olarak temin edilebilen sözlük listeleri bulunur.

Sözlük listelerinin güncel ve hedefe uygun olması, başarının anahtarıdır.



Sözlük Saldırısı vs. Kaba Kuvvet

Sözlük saldırıları mantık olarak kaba kuvvet saldırılarına benzer. Ayıran temel fark, deneme ihtimallerinin özelleştirilmesi ve denenme süreçlerinin daha hedefe yönelik olmasıdır. Çözülmeye çalışılan şifre ile ilgili ne kadar bilgi toplanırsa, o kadar özelleştirilmiş sözlük listeleri oluşturulabilir. Sözlük saldırılarını önlemek için şifre giriş alanları belli deneme sayılarıyla sınırlandırılır.

Crunch Aracı

Crunch, Kali Linux off-line password menüsünde hazır olarak gelen, kullanıcı isteğine göre özelleştirilmiş kelime listeleri hazırlayan bir araçtır. Kaba kuvvet saldırılarında basit kelime listelerinin yetersiz kaldığı durumlarda Crunch ile oluşturulan özelleştirilmiş sözlük listeleri önemli işlev görür. Crunch komutu temel olarak şu şekildedir: `crunch <min> <max>` (özelleştirilmiş seçenekler).

Crunch Temel Kullanım Parametreleri

Min: Minimum karakter sayısını belirtir.

Max: Maksimum karakter sayısını belirtir.

-o (Option): Çıktı dosyasını belirtir (Output).

-p (Pattern): Kelime dizisi kalıbı belirlemek için kullanılır.

Terminalde 'Man crunch' yazılarak tüm parametreler hakkında detaylı bilgi alınabilir.

Crunch ve Charset.lst

Crunch, özelleştirilmiş sözlük listeleri oluşturulurken charset.lst isimli dosyayı kullanır.

Bu dosyanın içinde çeşitli karakter kümeleri (örneğin, 'numerics', 'alphabetic') bulunur.

Bu kümelerden faydalanılarak kullanıcıya özgü yeni sözlük listeleri oluşturulabilir.

Yalnızca rakamlardan oluşan bir liste istendiğinde 'numerics' charseti kullanılmalıdır.



Crunch Karakter Kalıpları

- t parametresi ile kullanılabilen bazı özel karakterler ve görevleri şunlardır:
- @ işareti: Küçük harfli karakterleri yazdırmak için kullanılır.
- , işareti: Büyük harfli karakterleri yazdırmak için kullanılır.
- % işareti: Rakam yazdırmak için kullanılır.
- ^ işareti: Özel karakterler yazdırmak için kullanılır.

Uygulama 5: Crunch ile Özelleştirilmiş Liste Oluşturma

Hedef: Yalnızca rakamlardan oluşan minimum 1, maksimum 4 karakterli 'yeniliste.txt' isimli bir sözlük listesi oluşturmak.

Komut: root@Kali: crunch 1 4 -f /usr/share/crunch/charset.lst numeric -o yeniliste.txt.

-f parametresi ile charset küme değeri 'numeric' olarak tanımlanmıştır.

-o parametresi ile çıktı dosyası (yeniliste.txt) oluşturulmuştur.

Uygulama 5: Karmaşık Kalıp Oluşturma

Hedef: 10 karakterli, ilk dört karakteri '1881', son 2 karakteri 'mk' olan ve aradaki diğer dört karakterin tamamı büyük harflerden oluşan liste ('tutumluolun.txt') oluşturmak.

Komut: root@Kali: crunch 10 10 -t 1881,,,,mk -o tutumluolun.txt.

'1881' ve 'mk' sabit kalırken, aradaki dört virgül (,) büyük harflerle temsil edilen değişken karakter havuzunu ifade eder.



Rainbow Tabloları

Rainbow table, parolaların düz (salt) ve şifrelenmiş (hash) hâlinin bulunduğu önceden hesaplanmış tablolarıdır.

Rainbow tablolarının temel kolaylığı, saldırganın her parola için uygun hash algoritmasını tekrar hesaplama ihtiyacını ortadan kaldırmasıdır.

Saldırgan, veri tabanından elde ettiği şifrelenmiş parolayı (hash), tablodaki önceden hesaplanmış hash'lerle karşılaştırarak orijinal parolaya hızlıca ulaşabilir.



Salt Kavramı ve Güvenlik

Salt, veriler hash algoritmalarından geçirilirken rainbow tablosu saldırılarıyla kolayca kırılmaması için verinin sonuna, başına veya ortasına yerleştirilen rastgele karakter dizisidir.

Sistem yöneticileri, her parolaya farklı bir 'salt' ekleyerek parolaların hash hâllerini saklarlar; bu, her hash'in benzersiz olmasını sağlar.

Örnek: Siber $\rightarrow$ hash $\rightarrow$ 1123... vs. Siber + Salt (+++) $\rightarrow$ Siber+++ $\rightarrow$ hash $\rightarrow$ 1823....



Key Stretching (Anahtar Uzatma)

Key stretching, rainbow tablosu saldırılarına karşı kullanılan bir diğer siber güvenlik yöntemidir.

Bu yöntemde, salt şifre ve bazı ara karma değerler, karma fonksiyonunda birçok defa işlenir.

Bu işlem, her bir şifrenin karma değerini hesaplamak için gerekli sürenin uzamasını sağlar, böylece çevrimdışı saldırı süresi artırılır.

Klasik hashleme ile rainbow tabloları arasında zaman ve bellek arasında bir tercih durumu bulunur.



Rainbowcrack Aracı

Rainbowcrack, Kali araçları içinde hem rainbow tabloları oluşturulmasını hem de bu tabloları kullanarak saldırı yapılmasını sağlayan açık kaynak kodlu bir araçtır.

Araç, rtgen ile tabloları oluşturur, rtsort ile tabloları sıralar ve rcrack ile özetlerin tablodaki eşlerini bulur.

Rainbowcrack'a Kali Linux'ta 'Password Attacks > Offline Attacks > rainbowcrack' yoluyla ulaşılır.



Rainbowcrack (rtgen) Komut Yapısı I

rtgen özet_algoritma karakter_seti minimum_karakter_sayısı
maksimum_karakter_sayısı tabloların_sıralanması zincir_uzunluğu
zincir_sayısı tablo_başlangıç_sayısı şeklinde kullanılır.
Özet_algoritma: LM, NT, md5, sha1 gibi hash tipleri belirtilir.
Karakter_seti: 'charset.lst' dosyasında bulunan karakter kümeleri kullanılır
(alphanumeric, numeric vb.).

Rainbowcrack (rtgen) Komut Yapısı II

Zincir_uzunluğu: Her bir zincirin uzunluğunu belirtir (Örn: 1000, 10000). Daha büyük değer, başarı oranını artırırken, parola kırma süresini de artırır.

Zincir_sayısı: Üretilcek zincirlerin sayısını belirtir. Maksimum değer 134217728'dir, bu da yaklaşık 2 GB'lık bir dosya üretir.

Tablo_başlangıç_sayısı: Her zincir için başlangıç değerinin kaç olacağı belirtilir (0, 1, 2,...).

Rainbow tablosu oluşturmak, kullanılan algoritma ve parametrelere bağlı olarak günler veya haftalar sürebilir.

Rcrack ile Hash Çözümleme

Rtgen ile oluşturulan tablolar, Rcrack ile kullanılmadan önce rtsort aracıyla sıralanmalıdır.

Rcrack, eldeki özetlerin (hash'lerin) tablodaki eşlerini bulacak olan temel araçtır.

Temel kullanım şekli: `rcrack kullanılacak_tablo.rt -seçenek hash_hash_dosyası`.

Seçenekler: `-f` (pwdump dosyası), `-l` (içinde özetlerin bulunduğu bir dosya), `-h` (direkt olarak özetin kendisi).

Teknik Olmayan Parola Atakları

Teknik olmayan saldırılar, herhangi bir teknik bilgi veya donanım gerektirmeden yapılan saldırılardır.

Bu atak türlerinin temelinde, sistemin teknik zayıflıkları yerine insan faktörü (sosyal mühendislik) ve fiziksel/gözlemsel açıklar yatar.

En yaygın örnekler:

Sosyal mühendislik yöntemleri kullanmak.

Keylogger programları kullanmak (klavye hareketlerini kaydetmek).

Fiziksel takip veya omuz sörfü yapmak (Shoulder Surfing).



Teknik Olmayan Atak Örnekleri

Kullanıcı girişı gerektiren sitelere girme denemeleri, bu tür saldırıların bir başlangıcı olabilir.

'Pass the Hash' tarzı araçları kullanmak (ele geçirilen hash'i parola olarak kullanmak) bu atak türlerinin yaygın örneklerindendir.

Keylogger kullanımı, saldırganların klavyeden girilen tüm bilgileri kaydetmesini sağlar.



Teknik Olmayan Saldırlara Karşı Önlemler

Özellikle sosyal mühendislik yoluyla şifre elde etmeye çalışan kişilere karşı dikkatli olunmalıdır.

Bu tür saldırıları önlemek için alınabilecek başlıca önlemler şunlardır:

Cihazların güvenlik protokollerinin güncel olması.

Antivirüs programı kullanılması.

En önemlisi, kullanıcıların yüksek dijital okuryazarlığa sahip olması.



Özet ve Değerlendirme I

Parola ve Şifre, gizleme amaçları farklı olan kavramlardır (Parola: Kimlik doğrulama dizesi, Şifre: Kodlanmış bilgi).

Hash, veriyi sabit uzunlukta çıktıya dönüştürür ve tek yönlüdür.

Çevrimiçi ataklar anlık sistemleri hedefler (Hydra, Medusa), çevrimdışı ataklar hash dosyalarını hedefler (John, Hashcat).

Özet ve Değerlendirme II

Kaba Kuvvet Saldırısı, deneme yanılma yöntemine dayanır ve Hydra/Medusa ile otomatikleştirilir.

Sözlük Saldırısı, önceden hazırlanmış listeleri kullanır ve Crunch gibi araçlarla liste oluşturulur.

Rainbow Tabloları, hashleri önceden hesaplayarak kırma süresini kısaltır (Rainbowcrack).

Teknik Olmayan Ataklar, sosyal mühendislik ve keylogger gibi yöntemleri içerir.



Siber Güvenlikte Parola Kırma Teknikleri

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

